

eQMS - GxP Document Management & Audit Trail System (Multi-Tenant SaaS)

1. Product Overview

The system is a **cloud-based, multi-tenant SaaS** platform designed to securely store, manage, retrieve, and track GxP-regulated documents.

It supports **small and medium-sized companies** that must comply with **21 CFR Part 11, EU Annex 11**, and other GxP data integrity requirements.

The system enables:

- Regulated document management,
- Controlled document access with full traceability,
- GxP-compliant audit trails,
- Strong, flexible access control (RBAC + ABAC),
- Immutable storage of audit logs,
- Cost-optimized operation (low early-stage load but scalable).
- Training assignment & tracking

2. Product Goals

Primary Goals

1. Provide a compliant, secure repository for regulated documents.
2. Ensure full traceability of all user actions in the system.
3. Offer flexible but safe multi-tenant isolation.
4. Keep operating costs low for early-phase adoption.
5. Provide an extensible architecture for future modules (e.g., workflows, e-signatures).

Non-Goals

- Not a full QMS system (only document & audit management).
- No requirement for real-time full-text search in MVP.
- No requirement for advanced workflow management (future).

3. Target Users (Personas)

1. End User / Document Consumer

- Reads documents.
- Needs intuitive filtering, quick access, and secure authentication.

2. Compliance Manager / QA Auditor

- Needs complete audit trail exports.
- Needs strong access control and traceability.
- Needs ability to perform compliance checks.

3. Administrator (Tenant Admin)

- Manages users and permissions.
- Configures policies and ABAC rules (within allowed boundaries).
- Manages metadata.

4. System Operator (Platform Admin)

- Oversees multi-tenant resources.
- Monitors health, cost, and security posture.

4. Key Product Objects

4.1. Document

- ID, TenantId
- Title, Description
- Version, Status (Draft/Released/Archived)
- Metadata (dynamic key-value pairs)
- Owner (UserId)
- Confidentiality level / Classification
- Storage location (blob reference)
- Integrity hash (SHA-256)

4.2. User

- ID, TenantId
- Email, Full Name
- Roles
- ABAC attributes (Department, Country, Clearance Level)

4.3. Permission Policy

- RBAC roles (Document.Read, Document.Write, Document.Update,...)
- ABAC rules (expression-based)
- Field-level ABAC rules (optional in later version)

4.4. Audit Event

- EventId
- TenantId
- Timestamp (UTC)
- Actor (UserId or System)
- EntityType (Document/User/Policy...)
- EntityId
- Action (CREATE, UPDATE, READ, DELETE)
- Before/After values (for CUD)
- IP Address
- Device info (optional)
- Policy version applied
- Reference to immutable blob entry

4.5. Tenant Configuration

- Security policies
- Retention rules
- Allowed storage regions
- Feature flags

5. Key Use Cases

5.1 MUST HAVE (MVP)

Document Management

- Upload a document
- Retrieve a document (metadata + file)
- Update metadata
- Versioning (overwrite file → creates new version)
- List documents with filtering (title, metadata, owner, status)

Access Control

- RBAC for actions
- ABAC for document visibility and field-level metadata visibility
- Policy enforcement at:
 - List-level (query transformation)

- Entity-level (after retrieval)
- Field-level (optionally strip fields)

Audit Trail

- Log all **CUD** actions using transactional SQL outbox
- Log all **View/Read** actions asynchronously via durable queue
- Store audit entries immutably in **Azure Blob (WORM)**
- Store metadata index in **Azure Table Storage** or Postgres table
- Provide audit trail export to CSV/JSON
- Provide at least a minimally filtered query:
 - by document
 - by user
 - by date range

Multi-Tenancy

- All objects and events scoped to TenantId
- Hard isolation in queries
- No cross-tenant visibility
- Shared infrastructure optimized for cost

Security

- Strong authentication (OIDC)
- Encrypted documents in storage
- Secrets managed by KeyVault
- API rate limiting

5.2 SHOULD HAVE (Post-MVP)

Audit UI

- Filter by user, object type, action type
- Paginated view of audit metadata

Field-Level ABAC

- Show/hide selected metadata fields based on attributes

Document Lifecycle Controls

- Finalization / sign-off / lock status

Metadata Schema Editing

- Admin can define metadata templates

5.3 NICE TO HAVE (Future Releases)

Workflow

- Review → Approve → Release pipeline

Full Text Search

- Azure Cognitive Search or Elastic

Real Time Notifications

- of changes, approvals

Data Residency per Tenant

- Configurable storage region

Training assignment & tracking

- Assign trainings and track progress

6. Functional Requirements

6.1 Document Operations

6.1.1 List Documents

- Accepts filters:
 - eq, neq, lt, gt
 - contains
 - array containsAny
- System must:
 - pre-evaluate applicable ABAC rules into query-level constraints
 - retrieve filtered list
 - post-evaluate entity-level policies
 - strip forbidden fields based on field-level ABAC
- All accesses must be logged asynchronously.

6.1.2 Get Document

Flow:

1. Identify applicable policies (RBAC+ABAC).
2. Evaluate entity-level access.
3. Strip fields if required.
4. Stream file from blob.
5. Log access asynchronously to queue.

6.2 Permission System

RBAC

Roles define coarse permissions (Document.Read, Document.Update, etc.).

ABAC

Policies expressed as simple boolean expressions:

```
1 document.ownerId == user.id
2 OR document.department IN user.allowedDepartments
3 AND document.classification <= user.clearance
4
```

Brackets allowed but validated during ingestion.

Policies stored in SQL as structured expressions (AST-like).

6.3 Audit Trail

6.3.1 Architecture

- **Write Events:**

- Use SQL Outbox pattern (atomic with business action)

- **Read Events:**

- Push to Service Bus (Basic tier)
- Worker writes to Blob immutably (WORM)
- Metadata index updated

6.3.2 Querying

- Auditor UI queries metadata index
- System returns:
 - Downloadable CSV (preferred)
 - Or JSON export

6.3.3 Auditor Access

- Restricted to special “Compliance Manager” role

- Normal users cannot read audit trail

7. Non-Functional Requirements (NFR)

7.1 Performance

- Document list < 200 ms for typical tenant
- Document retrieval < 300 ms
- Audit write latency:
 - CUD: synchronous
 - READ: <5 seconds (async acceptable)

7.2 Reliability

- Zero lost audit events (queue must be durable)
- End-to-end idempotency on event processing
- Automatic reconciliation job verifying:
 - Outbox vs. blob store consistency
 - Queue vs. blob store consistency

7.3 Security

- No user can delete or modify audit events
- All sensitive fields encrypted at rest
- Blob storage under WORM policy (7–10 years retention)

7.4 Scalability

- Horizontal scale-out for API
- Audit processing worker autoscaling
- Document storage scalable via Azure Blob
- Expected concurrency:
 - MVP tenants: ~1k events/day
 - Future: millions

7.5 Multi-Tenancy Isolation

- Every DB query requires TenantId predicate
- No cross-tenant objects
- Audit trail stored in shared but logically isolated blobs:

- e.g., `/audit/{tenantId}/yyyy/mm/dd/*.jsonl`
-

8. API Requirements

8.1 API Style

- REST for all document operations
- REST + simple filtering syntax:

```
1 GET /documents?title.contains=abc&ownerId=123
2
```

8.2 Audit Export API

```
1 GET /tenants/{id}/audit/export?from=...&to=...
2
```

Returns:

- File (CSV)
- Metadata: total events, hash, signature (optional)

9. Validation & Compliance Requirements

9.1 GxP Validation Items

- System must pass:
 - Installation Qualification (IQ)
 - Operational Qualification (OQ)
 - Performance Qualification (PQ)
- Controlled change management.
- SOPs for:
 - Audit trail retention
 - Backup and restore
 - Access review

9.2 Technical Controls (21 CFR Part 11)

- Unique user IDs
- Audit trail for all changes
- Cannot disable audit trail
- Timestamping in UTC
- Proper electronic signatures (future release)

10. MVP Scope Summary

Feature	Included?
Document CRUD	✓
RBAC + ABAC	✓
Audit trail (blob + index + export)	✓
Multi-tenant separation	✓
Simple UI for documents	✓
Auditor export endpoint	✓
Field-level ABAC	✗
Audit UI	✗
Workflows	✗
Full text search	✗
Electronic signatures	✗
Trainings	✗

11. Open Questions (for next phase)

1. Should tenant admins be allowed to create custom ABAC policies, or only RBAC?
2. Should audit exports include digital signature for long-term integrity verification?
3. Should large tenants be offered isolated storage accounts for compliance reasons?
4. Should we support schema versioning for metadata?